



Cuestionario: Responda y Fundamente su Respuesta

1. ¿Cuál es la función principal de un Firewall de Aplicaciones Web (WAF)?

- A.** Revisar los equipos que acceden a la red para comprobar que cumplan con las políticas de seguridad, como las actualizaciones del antivirus.
- B.** Filtrar, supervisar y analizar el tráfico HTTP y HTTPS entre una aplicación web e Internet para protegerla de ataques específicos.
- C.** Bloquear el tráfico basándose únicamente en las direcciones IP y los puertos de origen y destino.
- D.** Cifrar todo el tráfico de la red para crear una conexión segura a través de redes no confiables.
- B.** Filtrar, supervisar y analizar el tráfico HTTP y HTTPS entre una aplicación web e Internet para protegerla de ataques específicos.

2. ¿Qué característica fundamental diferencia a un firewall stateful (con estado) de uno stateless (sin estado)?

- A.** El seguimiento del estado de las conexiones activas, permitiendo distinguir el tráfico legítimo según el contexto de la sesión.
- B.** La velocidad de procesamiento, ya que los firewalls stateless son siempre más lentos por su análisis detallado.
- C.** La capacidad de filtrar contenido web, como bloquear el acceso a ciertas páginas.
- D.** La implementación exclusiva en hardware, mientras que los firewalls stateless son solo software.



3. En la configuración de un firewall, ¿qué implica la política de "denegar por defecto" (deny by default)?

- A.** Todo el tráfico, tanto entrante como saliente, se bloquea a menos que haya una regla que lo permita explícitamente.
- B.** Se permite todo el tráfico excepto el que proviene de una lista de direcciones IP maliciosas conocidas.
- C.** Solo se bloquea el tráfico entrante, mientras que todo el tráfico saliente se permite sin restricciones.
- D.** El firewall rechaza las conexiones y envía un mensaje ICMP al emisor para informarle del bloqueo.

4. ¿Cuál es el propósito principal de una Zona Desmilitarizada (DMZ) en una arquitectura de red con firewall?

- A.** Alojar servidores que deben ser accesibles desde Internet, como servidores web o de correo, aislándolos de la red local (LAN).
- B.** Filtrar el tráfico entre los propios equipos de la red local para evitar la propagación de amenazas internas.
- C.** Crear una red interna adicional con mayores niveles de seguridad para almacenar datos críticos.
- D.** Conectar directamente dos redes locales de diferentes sucursales de una empresa de forma segura.

5. Según las directrices del NIST, la Traducción de Direcciones de Red (NAT) se considera principalmente una tecnología de:

- A.** Enrutamiento, aunque a menudo se implementa en firewalls y proporciona un beneficio de seguridad secundario.
- B.** Cifrado, porque protege la confidencialidad de los datos.
- C.** Autenticación, ya que verifica la identidad de los usuarios.
- D.** Seguridad, siendo su función principal la de un firewall.



6. En iptables, la herramienta de firewall de Linux, ¿qué cadena (chain) se utiliza para procesar los paquetes que atraviesan el sistema hacia otro destino en una red diferente?

- A. FORWARD
- B. PREROUTING
- C. OUTPUT
- D. INPUT

7. ¿Qué tipo de ataque intenta agotar los recursos de un servidor web mediante el envío masivo de solicitudes GET o POST, y puede ser mitigado por un WAF?

- A. Recorrido transversal de ruta (Path Traversal)
- B. Saturación HTTP (HTTP Flood)
- C. Inyección SQL
- D. Clickjacking

8. Un firewall que intercepta una conexión y establece dos comunicaciones separadas (una con el cliente y otra con el servidor de destino) se conoce como:

- A. Gateway de proxy de aplicación (Application-Proxy Gateway)
- B. Firewall de inspección stateful
- C. Firewall de filtrado de paquetes
- D. Firewall para infraestructuras virtuales

9. En un ataque de "envenenamiento ARP" (ARP spoofing) con el objetivo de realizar un ataque Man-in-the-Middle (MITM), ¿qué información se falsifica?

- A. Los certificados SSL/TLS para hacerse pasar por un sitio web seguro.
- B. La dirección IP de origen en los paquetes TCP para suplantar a otro equipo.



C. Las respuestas a las consultas DNS para redirigir el tráfico a un sitio malicioso.

D. Las respuestas ARP para asociar la dirección IP de una víctima con la dirección MAC del atacante.

10. ¿Cuál es la principal desventaja de usar una política de firewall de "aceptar por defecto" (policy ACCEPT)?

A. Aumenta la complejidad de la administración, ya que se deben crear reglas para cada tipo de tráfico permitido.

B. Impide la comunicación con redes externas, bloqueando el acceso a Internet por completo.

C. Puede dejar la red expuesta a amenazas no previstas, como un nuevo servicio instalado que abre un puerto desconocido.

D. Reduce el rendimiento del firewall debido al gran número de reglas de bloqueo que se deben procesar.

11. Un dispositivo de seguridad que integra múltiples funciones como firewall, antivirus, prevención de intrusiones (IPS) y antispam en una sola máquina se conoce como:

A. Sistema de Detección de Intrusos (IDS)

B. Gateway de proxy de aplicación

C. Router-firewall doméstico

D. Gestor Unificado de Amenazas (UTM)

Un dispositivo de seguridad que integra múltiples funciones como firewall, antivirus, prevención de intrusiones (IPS) y antispam en una sola máquina se conoce como:

A. Sistema de Detección de Intrusos (IDS)

B. Gateway de proxy de aplicación

C. Router-firewall doméstico

D. Gestor Unificado de Amenazas (UTM)



12. Al comparar la escucha de tráfico TELNET frente a SSH en un ataque Man-in-the-Middle, ¿cuál es la diferencia clave en términos de seguridad?

- A.** El tráfico SSH, incluidas las credenciales de inicio de sesión, viaja cifrado, mientras que el tráfico TELNET viaja en texto plano.
- B.** La autenticación en SSH es más débil que en TELNET, ya que no permite el uso de contraseñas complejas.
- C.** SSH requiere más ancho de banda que TELNET, lo que lo hace más vulnerable a ataques de denegación de servicio.
- D.** TELNET utiliza puertos no estándar, lo que lo hace más difícil de interceptar que SSH.

13. Un ataque de Falsificación de Solicitud del Lado del Servidor (SSRF) consiste en:

- A.** Insertar datos sospechosos en una aplicación como un comando para engañar a un intérprete, como en una base de datos.
- B.** Descubrir contenido y funcionalidad oculta de un sitio web mediante conjeturas por fuerza bruta sobre nombres de archivos y directorios.
- C.** Engañar a los usuarios para que hagan clic en algo diferente a lo que perciben, ocultando código malicioso en un control de apariencia legítima.
- D.** Inducir a la aplicación del lado del servidor a realizar solicitudes HTTP a un dominio arbitrario elegido por el atacante.



14. En el contexto de la Unión Europea, ¿cuál es el objetivo de la Directiva NIS2?

- A.** Mejorar el nivel común de ciberseguridad en toda la Unión, ampliando el alcance y reforzando los requisitos de la directiva NIS original.
- B.** Establecer estándares comunes de ciberseguridad solo para productos de hardware y software, como dispositivos IoT.
- C.** Proteger los datos personales de los ciudadanos y regular cómo las empresas los procesan, almacenan y transfieren.
- D.** Crear una única agencia de ciberseguridad para gestionar todos los incidentes de seguridad en los Estados miembros.

15. Según el "IPTABLES Manual práctico", ¿por qué es importante el orden de las reglas en un firewall?

- A.** El orden solo es importante para optimizar el rendimiento; no afecta la seguridad.
- B.** Las reglas se procesan en paralelo, por lo que el orden no afecta el resultado final.
- C.** Las reglas más restrictivas siempre deben ir al final para garantizar que se procesen después de las permisivas.
- D.** Un paquete se compara con cada regla secuencialmente, y la primera regla que coincide determina la acción a tomar.